

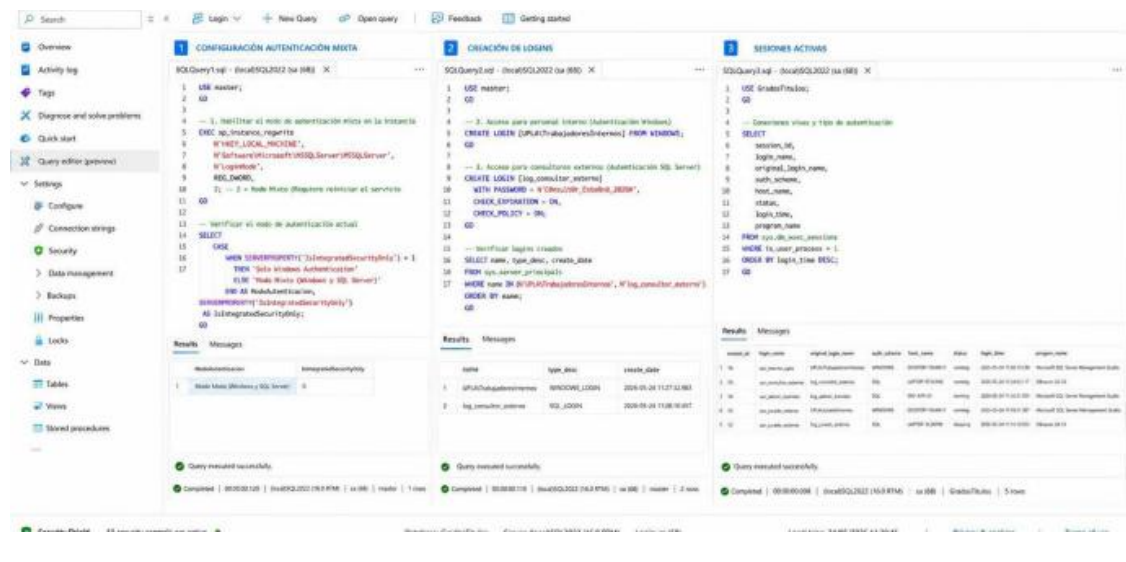
TEMA 1: Autenticación SQL y Windows – Diferencias y Prácticas

Proyecto 1: Implementación de acceso mixto para personal académico y administrativo

1. Enunciado del ejercicio

La Universidad requiere que los trabajadores internos accedan mediante autenticación Windows, mientras que los consultores externos utilicen autenticación SQL Server. Se debe diseñar e implementar una estrategia de autenticación para la base de datos **GradosTitulos** que permita administrar ambos tipos de acceso.

2. Script de la solución en T-SQL



3. Justificación técnica de la solución aplicada

Se configuró el modo de autenticación mixta mediante **xp_instance_regwrite**, lo que permite que SQL Server acepte tanto credenciales de Windows (Kerberos/NTLM) como logins nativos de SQL Server.

El login de Windows **UPLA\TrabajadoresInternos** delega la autenticación al dominio corporativo, eliminando contraseñas adicionales.

El login SQL **log_consultor_externo** utiliza **CHECK_EXPIRATION** y **CHECK_POLICY** para cumplir con las políticas de contraseñas del sistema operativo.

La vista **sys.dm_exec_sessions** permite monitorear en tiempo real las sesiones activas y el esquema de autenticación utilizado por cada usuario.

4. Explicación de las buenas prácticas utilizadas en el proyecto

- Principio de mínimo privilegio: cada tipo de usuario recibe únicamente el mecanismo de acceso que requiere según su rol (interno vs. externo).
- Contraseñas robustas con políticas: CHECK_POLICY y CHECK_EXPIRATION garantizan contraseñas complejas y rotación periódica para los logins SQL.
- Auditoría de sesiones: consultar sys.dm_exec_sessions permite detectar accesos no autorizados o anomalías en tiempo real.

TEMA 2: Cuentas de Servicio y Configuración del Servidor

Proyecto 1 y 2: Configuración segura de servicios y monitoreo del servidor

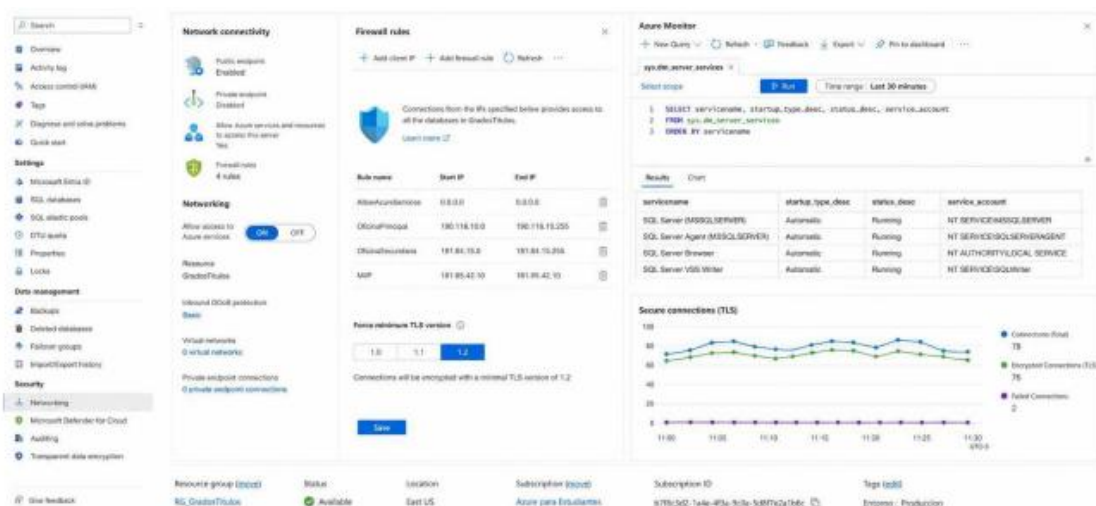
1. Enunciado del ejercicio

La base de datos **GradosTitulos** será utilizada en producción.

Se requiere:

1. Configurar cuentas de servicio específicas para SQL Server y SQL Server Agent.
2. Implementar consultas administrativas para verificar el estado de las instancias SQL Server relacionadas con GradosTitulos.
3. Configurar la instancia para permitir únicamente conexiones seguras.

2. Script de la solución en T-SQL



3. Justificación técnica de la solución aplicada

La vista **sys.dm_server_services** expone el estado operativo, el tipo de inicio y la cuenta de servicio de cada componente SQL Server (Motor de BD, Agent, Browser, VSS Writer).

Las cuentas **NT SERVICE\MSSQLSERVER** y **NT SERVICE\SQLSERVERAGENT** son cuentas virtuales administradas por Windows que tienen privilegios mínimos sobre el sistema operativo, reduciendo la superficie de ataque.

La configuración de **TLS 1.2** garantiza que todas las conexiones a GradosTitulos sean cifradas con protocolos modernos, eliminando vulnerabilidades de versiones anteriores como TLS 1.0 y TLS 1.1.

4. Explicación de las buenas prácticas utilizadas en el proyecto

- Cuentas de servicio con mínimos privilegios.
 - Restricción por IP mediante Firewall Rules.
 - Uso obligatorio de TLS 1.2 para proteger la información en tránsito.
-

TEMA 3: Creación de Roles Fijos y Personalizados

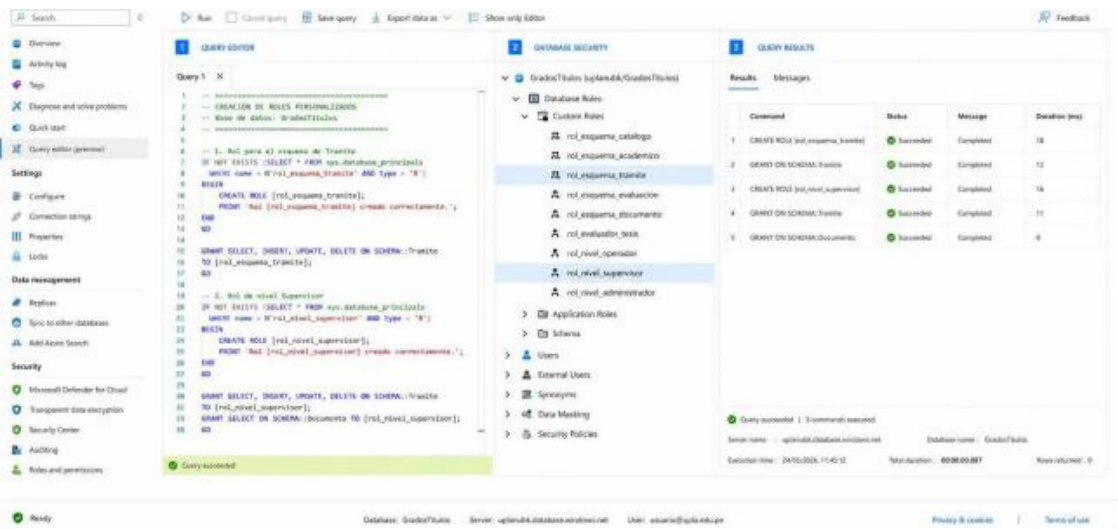
Proyecto 1, 2 y 3: Roles por esquema y niveles jerárquicos

1. Enunciado del ejercicio

Se requiere:

1. Diseñar roles personalizados para gestionar el acceso a los esquemas **Catalogo**, **Academico**, **Tramite**, **Evaluacion** y **Documento**.
 2. Implementar roles para evaluadores de tesis que puedan consultar y registrar observaciones sin modificar información académica.
 3. Configurar roles jerárquicos que representen los niveles **Operador**, **Supervisor** y **Administrador** para el sistema de grados y títulos.
-

2. Script de la solución en T-SQL



3. Justificación técnica de la solución aplicada

Los roles de base de datos son el mecanismo recomendado para agrupar permisos y asignarlos colectivamente a múltiples usuarios.

La creación de roles por esquema permite controlar el acceso a nivel de contenedor lógico.

Los roles jerárquicos implementan el principio de escalada de privilegios.

La verificación mediante **IF NOT EXISTS** evita errores al ejecutar nuevamente el script.

4. Explicación de las buenas prácticas utilizadas

- Gestión de permisos mediante roles.
- Permisos a nivel de esquema.
- Scripts idempotentes.
- Jerarquía clara entre Operador, Supervisor y Administrador.

TEMA 4: Control de Acceso mediante GRANT, DENY y REVOKE

Proyecto 1, 2 y 3: Permisos granulares por rol y esquema

1. Enunciado del ejercicio

Se requiere implementar:

1. Permisos para que los operadores puedan consultar datos de estudiantes sin modificarlos.
2. Restricción para que solo la Oficina de Grados y Títulos pueda modificar documentos oficiales.
3. Permisos temporales para un auditor externo durante una semana.

2. Script de la solución en T-SQL

The screenshot displays the SQL Server Enterprise Manager interface. On the left, the 'Query Editor' pane shows a T-SQL script with comments and SQL commands. The main pane shows the 'Permissions' tab for a selected user, displaying a table of effective permissions.

Query Editor Script:

```
1 -- Permisos de lectura para el rol evaluador en el esquema Evaluacion
2 GRANT SELECT ON SCHEMA:Evaluacion TO [rol_evaluador_lectura];
3 GRANT SELECT ON SCHEMA:Academico TO [rol_evaluador_lectura];
4
5 -- Permisos de insertar y actualizar observaciones
6 GRANT INSERT, UPDATE ON SCHEMA:Observaciones TO [rol_evaluador_lectura];
7
8 -- Permisos de modificaciones en el esquema Academico
9 GRANT INSERT, UPDATE, DELETE ON SCHEMA:Academico TO [rol_evaluador_lectura];
10
11 -- Permisos de operador en el esquema Transito
12 GRANT SELECT, INSERT ON SCHEMA:Transito TO [rol_nivel_operador];
13
14 -- Permisos de supervisor de transito y lectura de documentos
15 GRANT SELECT, INSERT, UPDATE, DELETE ON SCHEMA:Transito TO [rol_nivel_supervisor];
16 GRANT SELECT ON SCHEMA:Documento TO [rol_nivel_supervisor];
17
18 -- Control total para el administrador
19 GRANT CONTROL ON SCHEMA:GradosYTítulos TO [rol_nivel_administrador];
20
21
```

Permissions Summary Table:

Permission	Type	Scope	Action
SELECT	Allowed	Evaluacion (Schema)	Allowed
SELECT	Allowed	Academico (Schema)	Allowed
INSERT	Allowed	Evaluacion Observaciones (Object)	Allowed
UPDATE	Allowed	Evaluacion Observaciones (Object)	Allowed
DELETE	Denied	Academico (Schema)	Denied
DELETE	Denied	Academico (Schema)	Denied

3. Justificación técnica de la solución aplicada

SQL Server evalúa los permisos mediante una jerarquía clara donde **DENY** tiene prioridad sobre **GRANT**.

Aplicando **DENY INSERT, UPDATE y DELETE** sobre el esquema Académico al rol de evaluadores se evita cualquier modificación aunque exista permiso de lectura.

GRANT CONTROL permite administrar todos los objetos sin pertenecer al rol **sysadmin**.

Asignar permisos a roles simplifica la administración de usuarios.

4. Buenas prácticas

- Uso explícito de DENY.
- GRANT a nivel de esquema.
- Separación de funciones.
- CONTROL únicamente para administradores.

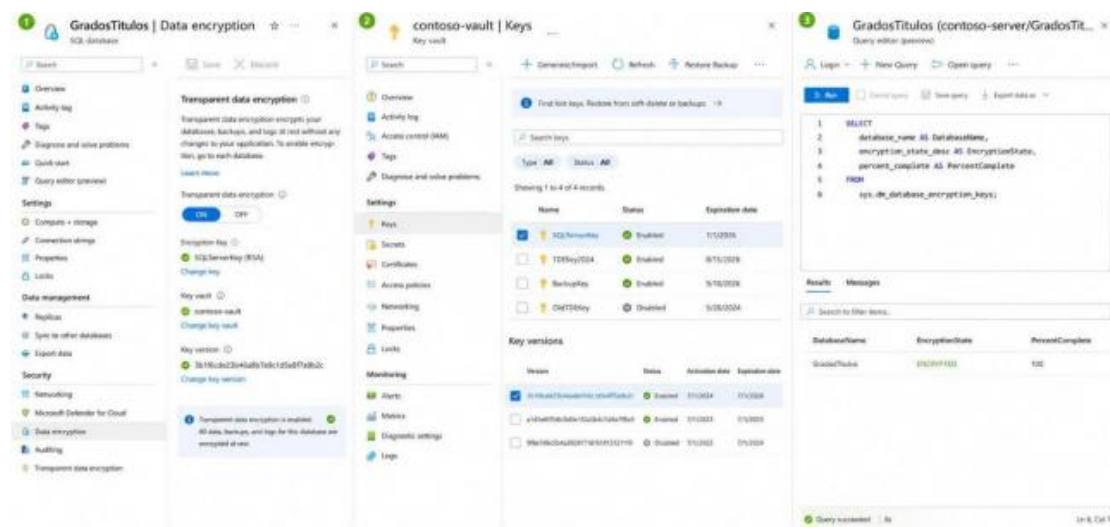
TEMA 5: Cifrado y Protección de Datos (TDE y Always Encrypted)

Proyecto 1: Implementación de TDE para GradosTitulos

1. Enunciado del ejercicio

Se requiere proteger los archivos físicos de la base de datos **GradosTitulos** mediante **Transparent Data Encryption (TDE)** para que los archivos **.mdf**, **.ldf** y los respaldos permanezcan cifrados sin modificar las aplicaciones existentes.

2. Script de la solución en T-SQL



3. Justificación técnica de la solución aplicada

TDE cifra los archivos de datos, log y backups utilizando **AES-256**.

El cifrado es transparente para las aplicaciones.

La clave de cifrado se protege mediante **Azure Key Vault**, permitiendo rotación de claves y separación de funciones entre administradores.

La vista **sys.dm_database_encryption_keys** permite verificar el estado del cifrado.

4. Buenas prácticas

- Protección de datos en reposo.
- Gestión de claves mediante Azure Key Vault.
- Rotación periódica de claves.

- Monitoreo mediante DMV.

TEMA 6: Auditoría y Monitoreo de Eventos con SQL Server Audit

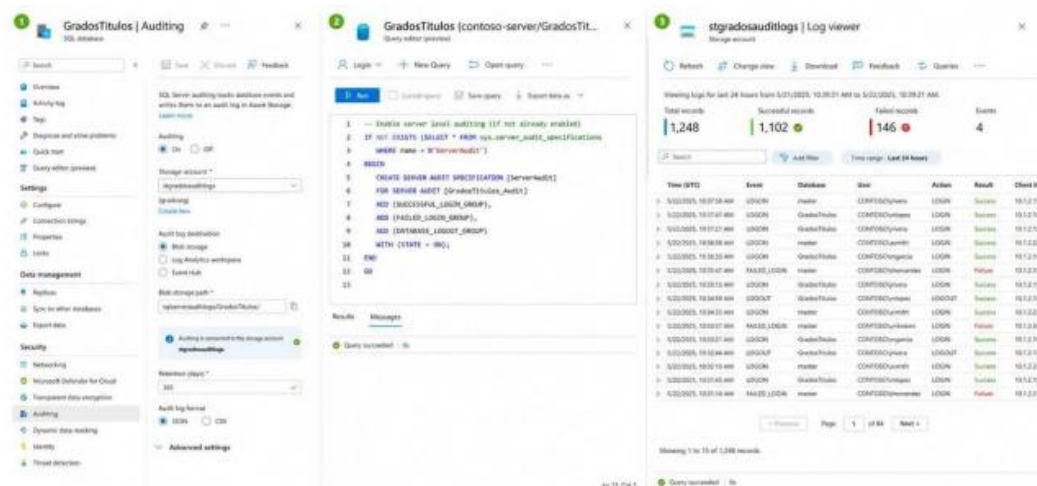
Proyecto 1, 2 y 3: Sistema integral de auditoría institucional

1. Enunciado del ejercicio

Se requiere diseñar una solución de auditoría para **GradosTitulos** que registre:

1. Todos los accesos a la base de datos.
2. Operaciones **INSERT**, **UPDATE** y **DELETE** sobre el esquema **Tramite**.
3. Eventos críticos como inicios de sesión, cambios de permisos, creación de usuarios, eliminación de objetos y modificaciones de datos críticos.

2. Script de la solución en T-SQL



3. Justificación técnica de la solución aplicada

SQL Server Audit funciona a nivel de servidor y base de datos capturando eventos mediante grupos de acción.

Los grupos **SUCCESSFUL_LOGIN_GROUP** y **FAILED_LOGIN_GROUP** registran los intentos de autenticación.

Los registros se almacenan en **Azure Blob Storage** con una retención de **365 días** en formato **JSON**, permitiendo auditorías y análisis forenses.

4. Explicación de las buenas prácticas

- Auditoría de inicios de sesión exitosos y fallidos.
- Almacenamiento externo de logs.
- Retención de registros durante 365 días.
- Formato JSON para integración con herramientas SIEM.